

セキュリティ技術評価

1. 本题考察的是支付卡行业信息安全标准——「PCI DSS (Payment Card Industry Data Security Standard)」的核心定义与目的。

- 核心考点解析：
 - PCI DSS的定义：为了保护信用卡及相关持卡人数据（Cardholder Data）的安全性，由国际主要信用卡组织联合制定的一套涵盖技术面与运营面要求的全球性安全标准。
 - 适用对象：所有处理、存储或传输信用卡持卡人数据的商户、服务提供商及支付网关。

选项解析与详细说明

- 为什么“PCI DSS”是正确答案？
 - 解析：题干明确指出其目的是“强化信用卡等卡会员数据的安全性（クレジットカードなどのカード会員データのセキュリティ強化）”，并且同时规定了技术面和运营面的要求。这正是 PCI DSS 的标准全称及设立初衷。
- 为什么其他选项是错误项或干扰项？
 - 选项1（ISMS適合性評価制度 / 信息安全管理体制适合性评估制度）→ 错误。ISMS（如 ISO/IEC 27001）是针对组织整体信息安全管理体制的通用标准，并非专门针对信用卡会员数据制定的专项安防标准。
 - 选项3（特定個人情報保護評価 / 特定个人信息保护评估）→ 错误。这是日本《番号法》（社会保障・税番号制度）规定的针对涉及“个人番号（マイナンバー）”的行政机关或企业进行的隐私影响评估制度，与信用卡无关。
 - 选项4（プライバシーマーク制度 / 隐私标志制度 / P-Mark）→ 错误。这是日本国内针对企业个人信息保护体制整体运营情况的认证制度（JIS Q 15001），并非国际通用的信用卡数据安全技术标准。

处理问题的排查表（安全标准与认证对照表）

标准/制度名称 (日语原件)	核心适用领域与目的
PCI DSS	专门针对信用卡及持卡人数据的技术与运营安全标准
ISMS適合性評価制度	组织整体信息安全管理体制（通用）
特定個人情報保護評価	日本“个人番号（My Number）”专属隐私评估
プライバシーマーク制度	日本国内通用的个人信息保护标志认证

考试小秘籍

◦ “PCI DSS 考点速记” 口诀：

- 看到题目出现 クレジットカード（信用卡）或 カード会員データ（卡会员数据）→ 脑中立刻闪现：「PCI DSS」！
- 考试属于送分题，抓准关键词“信用卡”和“安全标准”，直接秒选它！

2. 本题考察的是信息安全测试与评估方法中的核心概念——「ペネトレーションテスト（渗透测试）」的定义与实际运作方式。

◦ 核心考点解析：

- **什么是渗透测试（Penetration Test）**：由具备专业安全能力的测试人员，站在攻击者的视角（模拟真实黑客攻击），对公开的 Web 服务器、网络及系统进行主动的漏洞扫描与攻击尝试，**以验证是否能够实际入侵系统、获取控制权限。**
- **它与普通漏洞扫描的区别**：普通扫描只告诉你“这里可能有个洞”，而渗透测试则是“顺着这个洞真正钻进去，看看能不能把核心机密拿走或控制服务器”，属于动态、具有侵入性的实战演练。

选项解析与详细说明

◦ 为什么“公開Webサーバや組織のネットワークの脆弱性を探索し、サーバに実際に侵入できるかどうかを確認する。” 是正确答案？

- **解析**：该选项指出“探索公开 Web 服务器及组织网络的漏洞，并**确认是否能够实际侵入服务器**”。这完美契合了渗透测试的终极目标——通过模拟攻击验证系统的实际抗风险能力与防御边界。

◦ 为什么其他选项是错误项或干扰项？

- **选项1**（検査対象の実行プログラムの設計書, ソースコードに着目し, 開発プロセスの各工程にセキュリティ上の問題がないかどうかをツールや目視で確認する / 关注设计书与源代码, 通过工具或目视检查开发各环节是否存在安全问题）→ **错误**。这描述的是「セキュアコードレビュー（安全代码审查）」或静态代码分析，属于不运行程序的静态检查，不是渗透测试。
- **选项2**（公開Webサーバの各コンテンツファイルのハッシュ値を管理し, 定期的に各ファイルから生成したハッシュ値と一致するかどうかを確認する / 管理公开 Web 服务器各内容的哈希值, 定期检查是否与生成值一致）→ **错误**。这描述的是「ファイル完全性監視（文件完整性监测 / 防篡改检测）」，用于检查网页是否被黑客暗中篡改，属于系统运行中的监控手段。
- **选项4**（内部ネットワークのサーバやネットワーク機器のIPFIX情報から, 各PCの通信に異常な振る舞いがないかどうかを確認する / 通过网络设备的 IPFIX 信息, 检查各 PC 的通信是否存在异常行为）→ **错误**。这描述的是「振る舞い検知 / ログ監視（行为检测与流量日志监控）」，属于网络安全态势感知和监控，而不是渗透测试。

处理问题的排查表（安全测试方法辨析表）

选项涉及的操作手段	核心检查对象与行为特征	对应安全技术/方法
探索公开服务器漏洞，验证是否能实际入侵	模拟真实黑客攻击，验证实际入侵可能	ペネトレーションテスト (渗透测试)
检查设计书与源代码，找开发环节安全问题	静态检查代码和文档	セキュアコードレビュー (代码审查)
检查和管理文件的哈希值，防止文件被篡改	校验文件完整性	完全性監視 (完整性监测)
通过流量日志监控各 PC 通信的异常行为	分析流量与行为特征	ログ監視・振る舞い検知 (流量监控)

考试小秘籍

- “ペネトレーションテスト 考点速记” 口诀：
 - 看到 ペネトレーションテスト 找定义 → 脑中立刻锁定关键词：「実際に侵入（实际入侵）」、「攻撃者の視点（攻击者视角）」！
 - 考试只要看到选项里说“实际侵入服务器去验证”，闭眼选它绝对没错！
- 3. 本题考察的是支付卡行业数据安全标准——「PCI DSS（Payment Card Industry Data Security Standard）」中针对「カードセキュリティコード（卡安全码/CVV/CVC）」的极严格存储合规要求。
 - 核心考点解析：
 - 什么是卡安全码（Card Security Code）：指印刷在信用卡正面或签名栏上的 3 位或 4 位数字（如 CVV2 / CVC2）。
 - PCI DSS 的核心铁律（绝不能存储）：无论是以明文形式还是以加密形式，在完成授权（取引承認）之后，无论是加盟店（商户）还是服务提供商（Service Provider），绝对、任何情况下都严禁存储（保管しない）卡安全码。因为该密码仅用于交易授权瞬间的验证，存储它会带来极大的安全风险。

选项解析与详细说明

- 为什么表格中“加盟店：保管しない”且“サービスプロバイダ：保管しない”的选项（即选项工）是正确答案？
 - 解析：根据 PCI DSS 的硬性规定，交易授权完成后，无论是加盟店还是服务提供商，都绝对不能保管（保管しない）卡安全码。两者的处理方式都是“不保管”。因此，符合“保管しない / 保管しない”这一组合的选项工是唯一正确答案。
- 为什么其他选项是错误项或干扰项？
 - 选项ア、イ、ウ（涉及“暗号化して保管（加密保管）”或“平文で保管（明文保管）”）→ 全部错误。只要看到选项中允许加盟店或服务提供商在授权后以任何形式（加密或明文）“保管（保管する）”卡安全码的，全部都是违反 PCI DSS 规范的陷阱选项。

“银行卡安全码的‘看完即焚’铁律比喻”：

- **PCI DSS 的脾气**：卡安全码（背面那三位数字）就像是银行卡的安全密码。**加盟店和服务提供商**在帮顾客刷完卡、完成授权（取引承認）的那一秒钟之后，必须立刻把它忘得精光！
- **口诀**：不管是谁、不管加不加密，只要看到卡安全码（セキュリティコード），处理方法永远只有一个字——“不存（保管しない）！”两边都选“不存”，直接锁定最底下的选项工！

考试小秘籍

- “PCI DSS 卡安全码考点速记” 口诀：
 - 看到 カードセキュリティコード（卡安全码）的处理 → 脑中立刻闪现：「绝对不存（保管しない）」！
 - 考试在表格里找两边都是「保管しない」的那一行，闭眼选它，秒拿分数！

4. 本题考察的是日本及全球信息安全漏洞管理中极其重要的概念——CWE（Common Weakness Enumeration / 常见脆弱性类型枚举）的定义与作用。

- **核心考点解析**：
 - **什么是 CWE**：CWE 是一个由国际权威组织维护的、**软件与硬件缺陷/漏洞类型的标准分类目录（脆弱性の種類の一覧）**。它为各类系统安全漏洞（如缓冲区溢出、SQL注入、跨站脚本等）提供了一个统一的“字典”和编号分类体系。
 - **它与相关安全标准（CVE、CVSS）的区别**：
 - **CWE**：关注的是漏洞的“类型（是什么弱点）”（例如：SQL注入属于CWE-89）。
 - **CVE（Common Vulnerabilities and Exposures）**：关注的是具体的“漏洞实例（哪个软件在什么版本中出现了具体漏洞）”。
 - **CVSS（Common Vulnerability Scoring System）**：关注的是漏洞的“严重程度评分（基本/现状/环境三组指标）”。

选项解析与詳細説明

- **为什么“ソフトウェアの脆弱性の種類の一覧”是正确答案？**
 - **解析**：CWE 的全称是 Common Weakness Enumeration（常见脆弱性类型枚举），其核心本质就是为了对软件安全漏洞和弱点的“类型、种类”进行标准化分类和编号罗列（即脆弱性种类一览）。
- **为什么其他选项是错误项或干扰项？**
 - **选项1**（基本評価基準, 現状評価基準, 環境評価基準の三つの基準でIT製品の脆弱性を評価する手法 / 用基本、现状、环境三项指标评估IT产品漏洞的手法）→ 描述的是 **CVSS（Common Vulnerability Scoring System, 通用漏洞评分系统）**，而不是 CWE。

- 选项2（製品を識別するためのプラットフォーム名の一覧 / 用于识别产品的平台名称一览）→ 描述的是 **CPE（Common Platform Enumeration，通用平台枚举）**，用于统一命名和识别各种操作系统、硬件和应用程序。
- 选项3（セキュリティに関連する設定項目を識別するための識別子 / 用于识别与安全相关配置项的标识符）→ 描述的是 **CCSS 或 SCAP 体系中的 XCCDF/OVAL 配置检查相关标准**，并非 CWE。

考试小秘籍

◦ “CWE 考点速记” 口诀：

- 看到 **CWE** → 脑中立刻锁定：「種類の一覧（种类一览 / 字典）」！
- 看到“三基准评分”选CVSS，看到“平台名称”选CPE，看到“种类一览”直接选CWE！

5. 本题考察的是信息安全漏洞量化评估标准——CVSS（Common Vulnerability Scoring System / 通用漏洞评分系统）的核心特征与设计原则。

◦ 核心考点解析：

- **CVSS 的本质**：CVSS 是一个由 FIRST（论坛与事件响应安全团队）维护的、针对信息系统漏洞严重程度的开放且通用的评估体系（オープンで汎用的な評価手法）。
- **非特定厂商依赖**：它属于公开、客观的第三方标准，不依赖于任何特定的软硬件厂商（特定ベンダーに依存しない），任何厂商的系统或产品均可采用该标准对其漏洞进行统一打分和评级。

选项解析与詳細説明

◦ 为什么“情報システムの脆弱性の深刻度に対するオープンで汎用的な評価手法であり、特定ベンダーに依存しない評価方法を提供する。”是正确答案？

- **解析**：这精准概括了 CVSS 的核心定位——它是一个开放、通用的漏洞严重程度评估框架，不偏袒或绑定任何特定厂商（如微软、苹果或思科），由全行业共同遵循。

◦ 为什么其他选项是错误项或干扰项？

- 选项1（CVSSv2とCVSSv3は、脆弱性の深刻度の算出方法が同じであり、どちらのバージョンで算出しても同じ値になる / CVSSv2和CVSSv3的漏洞严重度计算方法相同，无论用哪个版本计算出的数值都一样）→ **错误**。CVSSv3 对 v2 进行了重大修订（引入了更科学的指标和范围度量等），两者的计算公式和最终分值体系并不相同。
- 选项3（脆弱性の深刻度を0から100の数値で表す / 用0到100的数值来表示漏洞严重度）→ **错误**。CVSS 的评分体系采用的是 **0.0 到 10.0** 的分值区间（分值越高越严重），而不是 0 到 100。

- 选项4（脆弱性を評価する基準は、現状評価基準と環境評価基準の二つである / 评估漏洞的基准只有现状评估基准和环境评估基准两个）→ **错误**。CVSS 实际上包含三个评估基准组合：**基本評価基準（基本基准）、現状評価基準（现状基准）和環境評価基準（环境基准）**，并非只有两个。

考试小秘籍

- “CVSS 考点速记” 口诀：
 - 看到 **CVSS** 考特点 → 脑中立刻锁定关键词：「オープンで汎用的な評価手法（开放且通用的评估手法）」、「特定ベンダーに依存しない（不依赖特定厂商）」！
 - 考试看到分值说“0-100分”或说“只有两个基准”的，直接打叉淘汰！
- 6. 本题考察的是信息安全漏洞量化评估系统——CVSS（Common Vulnerability Scoring System）中三大评估基准（基本、现状、环境）的具体分类与动态特征。
 - **核心考点解析：**
 - **CVSS的三大评估基准：**
 - i. **基本評価基準（Base Metric Group / 基本评估基准）：**评估漏洞本身的固有特征，**不随时间和使用环境而改变**。
 - ii. **現状評価基準（Temporal Metric Group / 现状评估基准）：**评估漏洞随时间推移而变化的特征（例如：攻击代码/Exploit的出现与成熟度、漏洞修复方案/补丁的可用性等），因此**随着时间的推移，评估结果会发生变化**。
 - iii. **環境評価基準（Environmental Metric Group / 环境评估基准）：**评估针对特定组织或用户实际使用环境的特征，因此**根据产品利用者的不同环境，评估结果各不相同**。

选项解析与详细说明

- 为什么“攻撃コードの出現の有無, 利用可能な対策のレベルなどに応じ, 評価結果は時間の経過で変化する。”是正确答案？
 - **解析：**这正是「現状評価基準（现状评估基准）」的核心定义。随着时间的推移，攻击代码（Exploit）是否被公开开发出来、官方是否发布了补丁等对策（利用可能な対策のレベル），都会直接影响漏洞的威胁程度，因此其评分会随时间演变而动态变化。
- 为什么其他选项是错误项或干扰项？
 - 选项2（脆弱性及び想定される脅威に応じ, 製品利用者ごとに評価結果は異なる / 根据漏洞及想定威胁，产品利用者的评估结果各不相同）→ **错误**。这描述的是「環境評価基準（环境评估基准）」的特征（因企业/用户的部署环境和资产价值不同而异）。
 - 选项3（製品利用者が脆弱性への対応を決めるための評価に用いる基準であり, 評価結果は時間の経過で変化しない / 用于帮助产品使用者决定应对漏洞的基准，且评估结果不随时间推移而变化）→ **错误**。现状评估基准正是会随着时间和对策成熟度而**发生变化的**。

- 选项4（評価結果は利用環境によらず同じで、かつ、時間の経過でも変化しない/评估结果与使用环境无关，且不随时间推移而变化）→ **错误**。这描述的是「基本評価基準（基本评估基准）」的特征（绝对恒定，与时间和环境无关）。

考试小秘籍

○ “CVSS 三大基准考点速记” 口诀：

- 看到 **現状評価基準** → 脑中立刻锁定关键词：「**時間の経過で変化する（随时间推移而变化）**」、「**攻撃コード（攻击代码）**」！
- 考试只要看到“随时间变”选现状，“因环境/用户不同而异”选环境，“怎么都不变”选基本！

7. 本题考察的是电子商务与信息安全中的核心基础设施——「**認証局（CA / 证书颁发机构）**」的**主要职责以及「デジタル証明書（数字证书）」**的签发对象。

○ 核心考点解析：

- **认证局（CA / 认证机关）的作用**：作为独立于交易双方的信任第三方机构（第三者機関），其核心职责是为通信双方的「**公開鍵（公钥）**」签发合法的数字证书（Digital Certificate），以证明该公钥确实属于对应的合法所有者，防止中间人攻击。
- **公钥与私钥的关系**：
 - **公開鍵（公钥）**：需要公开并由认证局（CA）为其颁发数字证书进行背书。
 - **秘密鍵（私钥）**：由用户自己严格秘密保存，**绝对不能**交由认证局保管或由其为私钥颁发证书。

为什么“取引当事者の公開鍵に対するデジタル証明書”是正确答案？

- **解析**：认证局（CA）的核心工作就是核实身份后，为交易当事者的「**公開鍵（公钥）**」**绑定身份信息并签发「デジタル証明書（数字证书）」**，从而在公开网络上建立信任。

“認証局 考点速记” 口诀：

- 看到 **認証局** 颁发证书 → 脑中立刻锁定：「**公钥（公開鍵）**」！
- 考试只要看到选项里出现“秘密鍵（私钥）”或者“密码（パスワード）”跟数字证书搭边的，直接打叉淘汰！

8. 本题考察的是美国联邦信息处理标准——「**FIPS 140（Federal Information Processing Standards Publication 140）**」的核心定义、适用对象及其在信息安全合规中的定位。

○ 核心考点解析：

- **FIPS 140 的定义与作用**：它是美国联邦政府的各级部门和机构在采购、使用时，对IT系统中包含的硬件及软件「**暗号モジュール（密码模块）**」所必须满足的安全要求进行规范的联邦标准。

- **核心保护对象：**其核心管制对象是实现加密、解密、散列、数字签名等功能的**密码模块（Crypto Module）**，而不是单纯的操作系统或普通的业务应用软件。

为什么 FIPS 140 聚焦于“暗号モジュール（密码模块）”？

- 在密码学应用中，算法本身是公开的，但密码算法在软硬件中的实现是否安全、是否存在侧信道攻击漏洞、密钥管理是否严密，完全取决于“密码模块”的封装与设计。FIPS 140 正是为了给这种加密核心部件设定统一的安全等级（Level 1 至 Level 4）而制定的国际知名标准。

“FIPS 140 考点速记” 口诀：

- 看到 **FIPS 140** → 脑中立刻闪现：「**美国联邦标准 + 密码模块（暗号モジュール）**」！
- 考试如果问你 FIPS 140 规定了什么，直接寻找选项中包含“暗号モジュール”（密码模块）的选项，闭眼选它绝对拿分！

9. 本题考察的是国际信息安全标准与评估体系中应用极为广泛的——「ISO/IEC 15408（通用标准 / Common Criteria, JIS版为 JIS X 5070）」的核心定义、适用范围及相关认证制度。

◦ **核心考点解析：**

- **ISO/IEC 15408 的定义与范围：**它是一项用于评估信息技术产品及系统安全特性的国际标准。其评估对象不仅限于专门的防火墙等安全产品，还包括操作系统（OS）、数据库（DB）、群件（Groupware）等所有需要保护资产和资源的软硬件系统。
- **JISEC 与 EAL 级别：**在日本，基于该标准由 IPA 运营第三方认证制度（JISEC），并通过评估保证级别（EAL: Evaluation Assurance Level）将其划分为 7 个等级（EAL1 ~ EAL7）。

为什么“ファイアウォール用ソフトウェア”等所有保护资源的软硬件均属评估对象？

- **解析：**很多人误以为只有像防火墙或杀毒软件这种“纯安全产品”才需要做 ISO/IEC 15408 评估。实际上，凡是包含敏感资源、需要进行权限控制和安全保障的系统组件（如操作系统、数据库等通用软件，以及硬件、固件），只要有安全需求，全部都在此国际标准的评估范围之内。

小学生级记忆法

◦ “信息产品的‘国家安全质检总局’比喻”：

- **ISO/IEC 15408** 就像是一个极其严格的“全能科技产品安全安检门”。
- 别以为只有保安公司（防火墙）要过安检，普通大楼的门禁系统（操作系统）、金库大门（数据库）、甚至大楼的硬件地基，只要里面藏了宝贝，都必须通过这个标准来测一测安全指数！
- 在日本，这个安检局的名字叫 **JISEC**，安检严格程度分为 7 个档次（**EAL1 ~ EAL7**）。

考试小秘籍

- “ISO/IEC 15408 考点速记” 口诀：

- 看到 ISO/IEC 15408 问范围 → 脑中立刻闪现：「不局限于防火墙，OS和数据库统统算（软硬件全覆盖）」！
- 看到评级 → 瞬间锁定：「JISEC」与「EAL1~EAL7（7个等级）」！

10. 本题考察的是密码学与信息安全管理中的核心概念——「暗号アルゴリズムの危殆化（密码算法的危殆化/失效/老化）」的定义与本质。

○ 核心考点解析：

- 什么是“危殆化（危殆化 / Compromise / Aging）”：在密码学中，随着时间的推移，计算机硬件算力的飞跃式提升（如量子计算或超级计算机的出现）、或者数学分析方法的进步，原本被认为是安全的密码算法变得不再安全、容易被破解的现象，称为密码算法的危殆化。
- 它与“密钥泄漏”的区别：危殆化是指算法本身或其数学强度因时代发展而失效，而不是因为管理员不小心把密码或密钥弄丢了。

选项解析与详细说明

○ 为什么“計算能力の向上などによって、鍵の推定が可能になり、暗号の安全性が低下すること”是正确答案？

- 解析：该选项指出“由于计算能力的提升等原因，导致密钥变得可以被推测，从而使密码的安全性下降”。这正是密码算法“危殆化”的经典定义——算力进步让旧算法失去了安全防线。

○ 为什么其他选项是错误项或干扰项？

- 选项1（外国の輸出規制によって、十分な強度をもつ暗号アルゴリズムを実装した製品が利用できなくなること / 因外国出口管制，导致无法使用具备充分强度的密码算法产品）→ 错误。这描述的是地缘政治与出口限制（輸出規制 / 法律与政策限制），与算法本身的数学危殆化无关。
- 选项2（鍵の不適切な管理によって、鍵が漏えいする危険性が増すこと / 因密钥管理不当，导致密钥泄漏的风险增加）→ 错误。这描述的是密钥管理不善导致的泄露风险（鍵の漏えい），属于运维失误，而非算法本身的危殆化。
- 选项4（最高性能のコンピュータを用い、膨大な時間やコストをかけて暗号強度をより確実なものにすること / 使用最高性能的计算机，花费庞大时间和成本使密码强度更确实）→ 错误。这描述的是主动通过高性能计算来增强加密或进行暴力破解测试的研发/攻击行为，文意完全相反。

处理问题的排查表（危殆化概念辨析表）

选项描述的现象 (日语原件)	其本质属于什么现象？
由于计算能力提升，导致密钥被破解、安全性下降	密码算法本身的“危殆化（老化失效）”
因为外国出口管制买不到强密码产品	贸易政策与出口管制限制
因为管理不善导致密钥泄露	密钥管理不当/人为失误
用高性能计算机去增强密码强度	主动计算/强化测试

小学生级记忆法

- “密码锁与时代眼泪的比喻”：
 - 危殆化（危殆化）就像是一把几十年前号称天下无敌的老式机械密码锁。
 - 当年它非常安全，但几十年后，小偷手里都有了激光切割机和超强算力（**計算能力の向上**），轻轻一算就把锁打开了。锁本身没坏，但它被时代淘汰、不安全了，这就叫“危殆化”。
 - 如果是因为钥匙掉进水沟（管理不善泄漏），那是丢钥匙；如果是因为造锁的材料被国家禁运了，那是出口管制。只有算力进步导致破解，才是真正的**危殆化**！

“危殆化 考点速记” 口诀：

- 看到 **危殆化** → 脑中立刻锁定关键词：「**計算能力の向上**（计算能力提升）」、「**安全性の低下**（安全性下降）」！
- 考试只要看到选项把危殆化解释成“算力提升导致密码失效”的，直接秒选它！